



Разработка паттерна для обеспечения безопасности веб-приложений нефтегазового комплекса при угрозе атак в облачной инфраструктуре

ВЫПОЛНИЛ

Лазорин Данил Сергеевич

группа КС-21-04

НАУЧНЫЙ РУКОВОДИТЕЛЬ

**Корнеев Николай
Владимирович**

д.т.н., профессор, кафедра комплексной безопасности
информационных технологий



РАЗДЕЛ 1

Актуальность работы

×2

*рост инцидентов в промышленном
веб-сегменте за 3 года
[Positive Technologies, 2026]*

№1

*XSS и №2 CSRF в OWASP Top 10
для веб-приложений АСУ ТП*

+400 мс

*задержки даёт промышленный WAF
— критично для диспетчеризации НГК*

ОГРАНИЧЕНИЯ СУЩЕСТВУЮЩИХ СРЕДСТВ ЗАЩИТЫ (WAF)

1 Анализируют HTTP-трафик, а не поведение пользователя — бот с валидным POST незаметен

2 Реализуются как отдельный прокси, добавляют 200–400 мс задержки — критично для АСУ ТП

3 Не адаптированы под аудиторию НГК — операторы 50+, медленная мышь, длинные паузы



РАЗДЕЛ 2

Цель работы

Повышение уровня безопасности

**веб-приложений нефтегазового комплекса
при угрозе атак в облачной инфраструктуре**

ИНСТРУМЕНТ ДОСТИЖЕНИЯ

Архитектурный паттерн

типовое архитектурное решение в виде микросервиса безопасности,
объединяющего сигнатурный анализ, защиту от XSS/CSRF,
поведенческий анализ траектории курсора и журналирование событий



РАЗДЕЛ 3

Задачи

1 Обзор литературы

и нормативной базы
Характеристика акторов, классификация
веб-приложений НГК

2 Модель угроз

по триаде КЦД
Экспертная оценка влияния угроз из БДУ
ФСТЭК

3 Формализация требований

FR / NFR / BR / ERR / UC + матрица
трассируемости + MoSCoW

4 Проектирование паттерна

в нотации UML Deployment Diagram
4 подсистемы + сервис безопасности

5 Поведенческий анализ

траектории курсора
Математическая модель из 7 формул

6 Программная реализация

на стеке Docker + Nginx + PHP 8.2 +
MySQL
16 листингов + 9 модулей анализа
курсора

7 Развёртывание в Kubernetes

+ стек мониторинга
Prometheus + Grafana + cAdvisor + Node
Exporter

8 Сравнительное тестирование

с ModSecurity v3 + NAXSI
на идентичном стенде Yandex Cloud



РАЗДЕЛ 4

Объект, предмет, научная новизна

ОБЪЕКТ ИССЛЕДОВАНИЯ

Веб-приложения нефтегазового комплекса в облачной инфраструктуре

ПРЕДМЕТ ИССЛЕДОВАНИЯ

Методы и механизмы обеспечения безопасности веб-приложений при угрозах атак в облачной инфраструктуре

НАУЧНАЯ НОВИЗНА

1

Архитектурный паттерн с инлайн-защитой

вместо WAF-прокси: задержка < 5 мс вместо 200–400 мс

2

Метод поведенческого анализа траектории курсора

на основе 6 геометрических признаков и шкалы HUMAN – SUSPICIOUS – BOT

3

Модель угроз с количественной оценкой КЦД

связана с моделью акторов и матрицей трассируемости



РАЗДЕЛ 5

Выдвинутые гипотезы исследования

H1 Точечность существующих решений

Существующие средства защиты веб-приложений НГК реализуются обособленно, что снижает эффективность противодействия XSS- и CSRF-атакам

H2 Актуальность XSS и CSRF

Наиболее актуальными угрозами для веб-приложений НГК являются XSS и CSRF — высшее влияние на триаду КЦД

H3 Отсутствие отеч. паттерна

В отечественной практике отсутствует единая архитектура паттерна, объединяющая все подсистемы защиты в составе одного микросервиса

H4 Поведенческий анализ

Анализ траектории курсора отличает оператора НГК от бота-имитатора при $TPR \geq 95\%$, $FPR \leq 5\%$, накладные расходы ≤ 10 мс



РАЗДЕЛ 5

Подтверждение гипотез

Гипотеза	Содержание	Способ подтверждения	Результат
Н1	Точность существующих решений	Обзор 30+ публикаций, разделы 1.1–1.3	✓ ПОДТВЕРЖДЕНА
Н2	Актуальность XSS и CSRF	Экспертная оценка КЦД, раздел 1.5.3	✓ ПОДТВЕРЖДЕНА
Н3	Отсутствие отечественного паттерна	Сравнение с ModSecurity / NAXSI, раздел 2.3.1	✓ ПОДТВЕРЖДЕНА
Н4	Поведенческий анализ траектории	12 векторов: TPR = 100 %, FPR = 0 % (раздел 4.6)	✓ ПОДТВЕРЖДЕНА



РАЗДЕЛ 6

Модель угроз: триада К — Ц — Д

ID БДУ ФСТЭК	Угроза	К	Ц	Д
УБИ.041	Межсайтовый скриптинг (XSS)	+	+	—
УБИ.042	Межсайтовая подделка запроса (CSRF)	—	+	—
УБИ.033	Слабости кодирования (SQLi и др.)	+	+	+
УБИ.017	Доступ / перехват HTTP cookies	+	+	—
УБИ.030	Использование данных по умолчанию	+	+	+
УБИ.006	Внедрение кода или данных	+	+	+

ВЫВОД

Угрозы УБИ.041 (XSS) и УБИ.042 (CSRF) одновременно нарушают конфиденциальность и целостность — приоритетные цели разрабатываемого паттерна.
Подтверждение гипотезы H2.



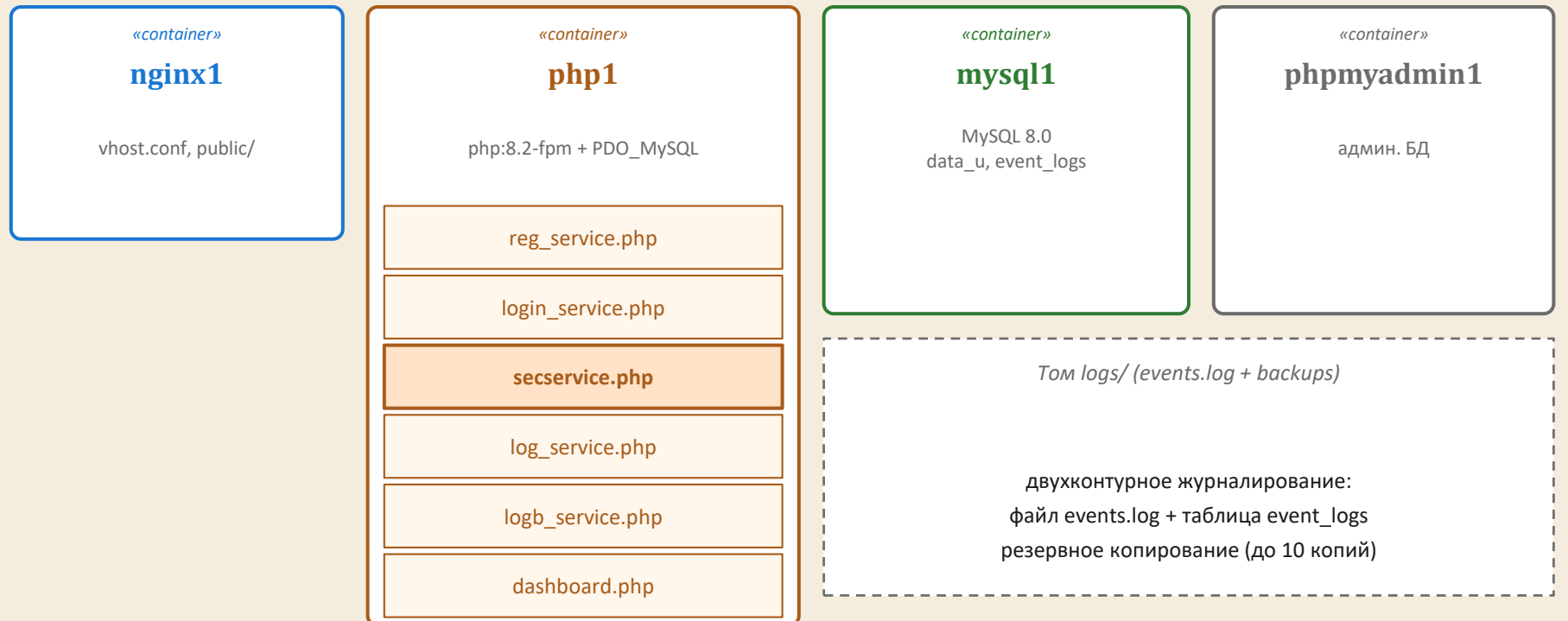
РАЗДЕЛ 7

Архитектура паттерна (UML Deployment)

Акторы

- A-1** Незарегистр. пользователь
- A-2** Оператор НГК
- A-3** Администратор безопасности
- A-4** Внешний нарушитель
- A-5** Бот-имитатор

«device» Облачный хост Linux + Docker Engine





ФИШКА РАБОТЫ

Подсистема анализа траектории курсора

«Отличает оператора НГК от бота-имитатора, генерирующего синтаксически валидный HTTP-трафик»

1. КЛИЕНТСКИЙ ТРЕКЕР

`cursor_tracker.js`

- Захват события `mousemove` с троттлингом 33 мс (~30 fps)
- Массив точек $\{x, y, t\}$, кольцевой буфер 3000 точек
- Подсчёт «резких скачков» > 300 px
- При submit формы — JSON в скрытое поле `cursor_path`

2. СЕРВЕРНЫЙ АНАЛИЗАТОР

`secservice.php` → `CursorAnalyzer`

- 6 геометрических признаков траектории
- Расчёт балла $B \in [0, 100]$
- Классификация: HUMAN / SUSPICIOUS / BOT
- Накладные расходы < 5 мс на запрос ($n \leq 3000$)



ФИШКА РАБОТЫ

Математическая модель анализа траектории

$$P = \{p_1, p_2, \dots, p_n\}, \text{ где } p_i = (x_i, y_i, t_i); \quad n = |P|; \quad T = t_n - t_1$$

(2.1)	Суммарный пройденный путь	$L = \sum_{i=1}^{n-1} \sqrt{(x_{i+1} - x_i)^2 + (y_{i+1} - y_i)^2}$	пикс.
(2.2)	Средняя скорость курсора	$\bar{v} = L / T$	пикс./мс
(2.3)	Коэффициент прямолинейности	$S = D / L, \text{ где } D = \ p_n - p_1\ $	$S \rightarrow 1 = \text{бот}$
(2.4)	Доля пауз	$I = N_{idle} / (n - 1), \quad N_{idle}: \Delta t > 500 \text{ мс}$	безразм.
(2.5)	Средняя кривизна	$\bar{\kappa} = (1/(n-2)) \cdot \sum_{i=2}^{n-1} \pi - \angle(p_{i-1}, p_i, p_{i+1}) $	рад



ФИШКА РАБОТЫ

Шкала классификации и поведенческий балл

Поведенческий балл (2.7)

$$B = 100 - \sum_{j=1}^7 w_j \cdot \delta_j$$

Веса признаков w_j

Число точек траектории < 5	-50
Время на странице < 3 с	-25
Число скачков > 20	-30
Скорость < 0,05 пикс./мс	-20
Скорость > 5 пикс./мс	-20
Прямолинейность > 0,985	-25
Доля пауз > 90 %	-15

Шкала вердиктов

HUMAN

$B \geq 70$

запрос пропускается

SUSPICIOUS

$30 \leq B < 70$

журналируется,
не блокируется

BOT

$B < 30$

HTTP 429 +
BEHAVIOR_ANOMALY



РАЗДЕЛ 8

Отличия от существующих решений в НГК

«Аналогов в отечественном нефтегазовом секторе нет: WAF западных вендоров запрещены к закупке (Указ Президента РФ № 166)».

Характеристика	Облач. WAF (Cloudflare, F5)	Открытый WAF (ModSecurity)	Библиотеки (OWASP ESAPI)	Разработанный ПАТТЕРН
Защита XSS	Да	Да	Да	Да
Защита CSRF	Частично	Нет	Нет	Да (встроено)
Поведенческий анализ курсора	Нет	Нет	Нет	Да (6 признаков)
Задержка при штатной нагрузке	200–400 мс	150–300 мс	< 5 мс	< 5 мс
Потребление ОЗУ (100 польз.)	> 1 ГБ	312 МБ	50 МБ	148 МБ
Панель администратора	Метрики	syslog	Нет	Canvas-визуализация
Адаптация под НГК	Невозм.	Ручная	Невозм.	Пороги в коде
Импортозамещение № 166	Нет	Да	Да	Да (Yandex Cloud)



РАЗДЕЛ 9

Используемый технологический стек

СЕРВЕРНАЯ ЧАСТЬ



PHP 8.2

PDO_MySQL, bcrypt, hash_equals



Nginx 1.24

TLS 1.3, HTTP/2, FastCGI



MySQL 8.0

data_u, event_logs, индексы



phpMyAdmin

администрирование БД

КОНТЕЙНЕРИЗАЦИЯ



Docker 24+

docker-compose.yml, 4 контейнера



Kubernetes 1.28+

config.yaml, горизонт. масштабирование



Composer

PHP-зависимости (PHPUnit)

МОНИТОРИНГ И ТЕСТЫ



Prometheus

сбор метрик



Grafana

2 витрины + алерты



cAdvisor / Node Exporter

контейнерные / системные метрики



Apache JMeter

нагрузочное тестирование



РАЗДЕЛ 10

Развёртывание в кластере Kubernetes

01

Манифест `config.yaml`

Deployment с 4 контейнерами + Service NodePort + PersistentVolumeClaim

02

`kubectl apply -f config.yaml`

Развёртывание пода в кластере. Проверка: `kubectl get pods` / `kubectl get svc`

03

`kubectl scale --replicas=N`

Горизонтальное масштабирование подсистемы безопасности по требованию NFR-5

СТЕК МОНИТОРИНГА: *Prometheus + Grafana + cAdvisor + Node Exporter · 2 готовые витрины, 3 алерта*



Форма регистрации и авторизации



Рады вас видеть



Пройдите регистрацию

ФИО



Email



Пароль



Повтор пароля



Зарегистрироваться

У вас есть аккаунт? [Войти](#)



Добро
пожаловать



Войдите в свой аккаунт

Email



Пароль



[Забыли пароль?](#)

Войти

У вас нет аккаунта? [Зарегистрироваться](#)



Панель администратора инцидентов

Панель инцидентов

admin@admin.ru — Администратор

Выйти

59
ВСЕГО СОБЫТИЙ

14
ЗАБЛОКИРОВАНО

2
НЕУДАЧНЫХ ВХОДОВ

43
УСПЕШНЫХ ВХОДОВ

Журнал событий

- Все
- XSS
- CSRF
- Поведение
- Неудачные
- Успешные

#	ВРЕМЯ	IP-АДРЕС	ДЕЙСТВИЕ	СТАТУС	ВЕРДИКТ	БАЛЛ	ДЕТАЛИ	
59	2026-06-04 09:29:43	172.18.0.1	LOGIN	Успех	HUMAN	100	Авторизован: admin@admin.ru IP: 172.18.0.1	
58	2026-06-04 09:28:43	172.18.0.1	LOGOUT	Успех	—	—	Пользователь: admin@admin.ru	
57	2026-05-30 18:51:31	172.18.0.1	LOGIN	Успех	HUMAN	100	Авторизован: admin@admin.ru IP: 172.18.0.1	
56	2026-05-30 18:51:15	172.18.0.1	LOGOUT	Успех	—	—	Пользователь: admin@admin.ru	
55	2026-05-30 18:51:01	172.18.0.1	LOGIN	Успех	HUMAN	100	Авторизован: admin@admin.ru IP: 172.18.0.1	
54	2026-05-30 18:50:43	172.18.0.1	LOGOUT	Успех	—	—	Пользователь: admin@admin.ru	



Детальный просмотр события: canvas-траектория

[← Вернуться к журналу](#)

Событие #57 — LOGIN

Метаданные

ВРЕМЯ

2026-05-30 18:51:31

IP КЛИЕНТА

172.18.0.1

СТРАНИЦА

/login_service.php

ДЕЙСТВИЕ

LOGIN

СТАТУС

SUCCESS

ПОВЕДЕНЧЕСКИЙ ВЕРДИКТ

HUMAN (балл 100/100)

ВРЕМЯ НА СТРАНИЦЕ

15 с

ДВИЖЕНИЙ МЫШИ

760

РЕЗКИХ СКАЧКОВ

1

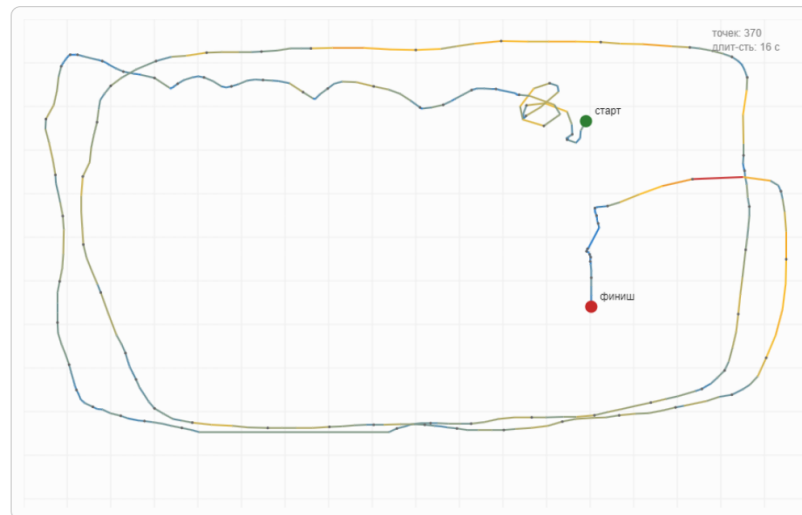
USER-AGENT

Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/130.0.0.0 Safari/537.36

ДЕТАЛИ

Авторизован: admin@admin.ru | IP:
172.18.0.1

Траектория курсора пользователя



Цвет линии — скорость курсора: **синий** = медленно, **жёлтый** = средне, **красный** = быстро. Зелёный круг — старт, красный — финиш.

370

точек траектории

8041.8

длина пути, px

0.5122

средняя скорость,
px/мс

0.0438

прямолинейность

15.7

длительность, с



ЭКСПЕРИМЕНТ

Идентификация 5 пользователей по курсорной динамике

ПОСТАНОВКА ЭКСПЕРИМЕНТА

5 испытуемых × 20 сессий = 100 траекторий

Форма регистрации / авторизации на одном стенде

Сбор данных: клиентский трекер `cursor_tracker.js`

Хранение: таблица `event_logs` в MySQL

Проверяемая гипотеза H4:

Поведенческий анализ траектории курсора позволяет отличить конкретного оператора с $TPR \geq 95 \%$, $FPR \leq 5 \%$.

РАСШИРЕННОЕ ПРИЗНАКОВОЕ ПРОСТРАНСТВО

12 ПРИЗНАКОВ

- Средняя скорость, медиана, ст. отклонение
- Среднее ускорение, максимальное ускорение
- Коэффициент прямолинейности S
- Средняя кривизна $\bar{\kappa}$
- Доля пауз I
- Джиттер (микроколебания)
- Средний угол поворота, ст. отклонение углов
- Общая длительность сессии

АЛГОРИТМ

- k-NN на евклидовом расстоянии
- Min-max нормализация в $[0; 1]^{12}$
- Профиль = центроид + ЕМА-обновление ($\alpha = 0,2$)



ЭКСПЕРИМЕНТ

Результаты: матрица 5×5 и точность

≈ 90 %

общая точность
идентификации

90 верных распознаваний
из 100 сессий

F1 - SCORE = 0,89

Лучший алгоритм: k-NN (k=3)

	user_1	user_2	user_3	user_4	user_5
user_1	20	0	0	0	0
user_2	0	19	0	0	1
user_3	0	0	17	3	0
user_4	0	0	3	17	0
user_5	0	1	0	0	19

Диагональ (зелёная) — корректные идентификации.

Пограничные случаи: user_3 ↔ user_4 (по 3 ошибки) — у этих испытуемых наиболее близкие профили средней скорости и кривизны.



ЭКСПЕРИМЕНТ

Анализ моделей и практическое применение

Сравнение алгоритмов классификации

Модель	Точность	Качество классификации (F-мера)
k-NN (k=3)	90,0 %	0,89
Decision Tree	84,0 %	0,83
Random Forest	88,0 %	0,87

ЛУЧШИЙ РЕЗУЛЬТАТ — k-NN

Простая интерпретируемая модель, объяснимая для службы информационной безопасности предприятия.

1

Подтверждение H4

Доля корректных блокировок ботов – 100 %, доля корректных идентификаций пользователя – 90 %. Гипотеза подтверждена количественно.

2

Применение в АСУ ТП НГК

Система обнаруживает подмену оператора за пультом — критический риск для технологических процессов нефтегазового комплекса.

3

Непрерывная аутентификация

Профиль обновляется через ЕМА ($\alpha = 0,2$). Новые пользователи распознаются автоматически после 2–3 сеансов.



Демонстрация работоспособности

#	ВРЕМЯ	IP-АДРЕС	ДЕЙСТВИЕ	СТАТУС	ВЕРДИКТ	БАЛЛ	ПОХОЖ НА	ДЕТАЛИ
82	2026-06-04 16:28:55	172.18.0.1	LOGIN	Успех	HUMAN	100	test@mail.ru 84%	Авторизован: admin@admin.ru IP: 172.18.0.1
81	2026-06-04 16:28:51	172.18.0.1	LOGOUT	Успех	—	—	— не опознан —	Пользователь: admin@admin.ru
80	2026-06-04 16:28:36	172.18.0.1	LOGIN	Успех	HUMAN	100	Оператор Иванов И.И. 61%	Авторизован: admin@admin.ru IP: 172.18.0.1
79	2026-06-04 16:28:31	172.18.0.1	LOGIN	Аномалия	—	—	— не опознан —	Аномальные скачки курсора: 25 IP: 172.18.0.1
78	2026-06-04 16:28:27	172.18.0.1	LOGIN	Аномалия	—	—	— не опознан —	Слишком быстрая отправка (2с) — возможен бот IP: 172.18.0.1
77	2026-06-04 16:28:24	172.18.0.1	LOGOUT	Успех	—	—	— не опознан —	Пользователь: admin@admin.ru
76	2026-06-04 16:23:35	172.18.0.1	LOGIN	Успех	HUMAN	100	admin@admin.ru 88%	Авторизован: admin@admin.ru IP: 172.18.0.1